

# PENETRATION TEST REPORT

*for*

# MEGAQUAGGA PUBLISHING



Version 1.0 (11/13/2025)

Prepared by **Zachary Lopater**

Presented to **MEGAQUAGGA PUBLISHING**

DISCLAIMER: This document contains proprietary and confidential information. 0x2A SECURITY guarantees the confidentiality of the information and any other material that has or will be disclosed during the performance of this service. A mutual non-disclosure agreement of confidential information is assumed between 0x2A SECURITY and MEGAQUAGGA PUBLISHING, limiting the use of confidential information exclusively for purposes associated with properly delivering this service.

# EXECUTIVE SUMMARY

A comprehensive penetration test was conducted to evaluate the security posture of Megaquagga Publishing. The assessment identified four significant vulnerabilities, all of which are directly attributed to outdated software versions. Although the specific weaknesses vary in scope and potential impact, each shares a common and relatively straightforward remedy—updating to current, supported versions and applying relevant security patches.

Two of the identified vulnerabilities are classified as high risk due to their ease of exploitation and public accessibility. These weaknesses could allow a threat actor to gain unauthorized entry with minimal effort, creating a direct path to sensitive systems and data. In a real-world attack scenario, this could result in a malicious actor acquiring direct access to high-level files and data, including potentially confidential or business-critical information. The simplicity of exploiting these vulnerabilities makes immediate remediation a priority.

The remaining vulnerabilities, while less accessible externally, carry potentially catastrophic implications if exploited. Successful exploitation could provide an attacker with advanced means of persistence within the network—allowing them to maintain long-term access, evade detection, and expand control across systems. Such persistence mechanisms could undermine remediation efforts and lead to sustained exposure of sensitive assets, operational disruption, and reputational harm.

Despite the seriousness of these findings, the overall situation is highly remediable. Since all vulnerabilities are due to outdated software, their resolution is both direct and achievable through a structured patching and update program. Implementing vendor-recommended updates, performing version audits, and establishing continuous monitoring will significantly reduce the organization's attack surface and prevent similar issues from recurring.

In summary, while the penetration test revealed multiple vulnerabilities that could enable both immediate compromise and long-term persistence, these weaknesses are not indicative of systemic design flaws. Rather, they reflect lapses in software maintenance and update management. By prioritizing software lifecycle governance and enforcing regular security patching, the organization can rapidly mitigate existing risks and substantially strengthen its defensive posture against future threats.

# SCOPE

The penetration test, conducted by 0x2A Security, focused on evaluating the security of the webserver identified in the prior vulnerability assessment. The engagement sought to determine whether the discovered vulnerabilities could be exploited under realistic conditions, assess the potential business and technical consequences, and provide actionable recommendations for remediation.

Testing was limited to the public-facing web infrastructure associated with *www.megaquagga.local*. This included the primary website and its directly connected backend services. All activities were confined to assets explicitly defined as in-scope to ensure precision, minimize operational risk, and comply with client authorization.

The defined scope included the following components:

- **Domain:** *www.megaquagga.local*, serving as the entry point for the web application and related backend services.

- **IP Address Range:** Only authorized addresses and subdomains directly tied to the target domain were tested, confirmed prior to engagement.

- **Assets Included:** The publicly accessible website and its backend systems were assessed for outdated software, configuration issues, and exploitable weaknesses.

- **Assets Excluded:** Internal networks, unrelated subdomains, and third-party services not explicitly listed in scope were excluded to avoid unintended impact.

To preserve operational integrity, several testing limitations were enforced. The engagement focused solely on exploitation of identified vulnerabilities without performing disruptive actions. Activities such as excessive brute-forcing, denial-of-service (DoS/DDoS) testing, or any form of data destruction or alteration were explicitly prohibited. These boundaries ensured that testing remained controlled, non-destructive, and representative of realistic threat behavior.

In summary, this penetration test was a focused, controlled engagement targeting known vulnerabilities within the defined public-facing environment. By maintaining strict boundaries and excluding high-risk testing methods, the assessment provided accurate, actionable insights into the organization's exposure while safeguarding production systems. The findings from this scope serve as a reliable foundation for prioritizing remediation and strengthening the organization's overall security posture.

# METHODOLOGY

## Pre-Engagement and Planning:

Megaquagga Publishing gave the 0x2A Security team clear goals and boundaries to achieve and operate within for the penetration test. All actions taken during the penetration test adhered to the request of and contract with Megaquagga Publishing, and was conducted within compliance of all regulatory agencies.

## Information Gathering (Reconnaissance):

I pinged the server to observe the output, and noticed no packets were being returned using ICMP, confirming that the firewall was blocking ICMP traffic. As a result, I reconfigured the firewall to all such traffic to flow in between the server and the Red Team workstation.

## Scanning:

Metasploit was used to scan for vulnerabilities along the server's attack surface. After configuring Metasploit for the test, I scanned the target server for hosts, services, and other information. Then, separately outside of Metasploit, I did a WPScan to scan for any vulnerable WordPress files, themes, plugins, or accounts. Following this scan, I discovered four plugins that were vulnerable due to outdated version patches.

## Exploitation:

Publicly available information confirmed that there is a proof of concept exploit readily available for three out of the four vulnerabilities discovered. Adjusting these exploits accordingly for our target, I was able to deploy these exploits and breach the server. The fourth vulnerability didn't have a specific exploit available, however, a simple tweak in one of the discovered exploits allows for a similarly easy breach of the target server.

## Post-Exploitation:

Once the target server was breached, I acquired administrative access and was able to operate undetected on the system. Through the installed Meterpreter, I was able to access, edit, and delete files and directories. I was also able to inject third-party code into publicly-accessible webpages.

# Reporting:

Research and testing proves that outdated versions of four Wordpress plugins - **TwentyTwenty, WP Advanced Search, WP File Upload,** and **Social Warfare** - are vulnerable to easily carried-out cyberattacks. In the following section, you will see more details on each vulnerability, including the severity and risk level.

# FINDINGS

## CRITICAL VULNERABILITIES

This section describes critical vulnerabilities discovered during this assessment.

| **Vulnerability** | **Outdated WordPress Core Version** |
|---|---|
| CVE | CVE-2024-9796 - WP Advanced Search |
| Severity | Critical (CVSS SCORE: 9.8) |
| OWASP Top 10 | A03 (Injection) |
| Risk | Risk is high, as publicly-available exploits exist |
| Steps to exploit | 1. Copied and pasted exploit url (found in CVE-2024-9796), adjusting parameters accordingly<br>2. Search for and gain access to high-level files and data |
| Evidence | WPScan output:<br><br>wp-advanced-search<br>\| Location: http://www.megaquagga.local/wp-content/plugins/wp-advanced-search/<br>\| Last Updated: 2024-11-05T18:15:00.000Z<br>\| [!] The version is out of date, the latest version is 3.3.9.3<br>\|<br>\| Found By: Urls In Homepage (Passive Detection)<br>\| Confirmed By: Urls In 404 Page (Passive Detection)<br>\|<br>\| Version: 3.3.3 (80% confidence)<br>\| Found By: Readme - Stable Tag (Aggressive Detection)<br>\|-http://www.megaquagga.local/wp-content/plugins/wp-advanced-search/readme.txt |

| **Vulnerability** | **Outdated WordPress Core Version** |
|---|---|
| CVE | CVE-2024-9047 - WP File Upload |
| Severity | Critical (CVSS SCORE: 9.8) |

| | |
|---|---|
| OWASP Top 10 | A07 (Identification and authentication failures) |
| Risk | Risk is high, as publicly-available exploits exist |
| Steps to exploit | 1. Copied and pasted exploit url (found in CVE-2024-9047), adjusting parameters accordingly<br>2. Search for and gain access to high-level files and data |
| Evidence | WPScan output:<br><br>wp-file-upload<br>\| Location: http://www.megaquagga.local/wp-content/plugins/wp-file-upload/<br>\| Last Updated: 2025-01-07T07:54:00.000Z<br>\| [!] The version is out of date, the latest version is 4.25.1<br>\|<br>\| Found By: Urls In Homepage (Passive Detection)<br>\| Confirmed By: Urls In 404 Page (Passive Detection)<br>\|<br>\| Version: 4.12.2 (50% confidence)<br>\| Found By: Readme - ChangeLog Section (Aggressive Detection)<br>\| - http://www.megaquagga.local/wp-content/plugins/wp-file-upload/readme.txt |

| **Vulnerability** | **Outdated WordPress Core Version** |
|---|---|
| CVE | CVE-2024-11352 - TwentyTwenty |
| Severity | Medium (CVSS SCORE: 6.4) |
| OWASP Top 10 | A03 (Injection) |
| Risk | Risk is low, as there is no known publicly-available exploit |
| Steps to exploit | 1. Installed Meterpreter implant on target system via RCE code deployed (CVE-2019-9978)<br>2. Gained administrative access to directories and files<br>3. Injected malicious code into publically-accessible web scripts |
| Evidence | WPScan output:<br><br>WordPress theme in use: twentytwenty<br>\| Location: http://www.megaquagga.local/wp-content/themes/twentytwenty/<br>\| Last Updated: 2024-11-13T00:00:00.000Z<br>\| Readme: |

| | |
|---|---|
| | http://www.megaquagga.local/wp-content/themes/twentytwenty/readme.txt<br>\| [!] The version is out of date, the latest version is 2.8<br>\| Style URL: http://www.megaquagga.local/wp-content/themes/twentytwenty/style.css?ver=1.0<br>\| Style Name: Twenty Twenty<br>\| Style URI: https://wordpress.org/themes/twentytwenty/<br>\| Description: Our default theme for 2020 is designed to take full advantage of the flexibility of the block editor...<br>\| Author: the WordPress team<br>\| Author URI: https://wordpress.org/<br>\|<br>\| Found By: Css Style In Homepage (Passive Detection)<br>\| Confirmed By: Css Style In 404 Page (Passive Detection)<br>\|<br>\| Version: 1.0 (80% confidence)<br>\| Found By: Style (Passive Detection)<br>\|-http://www.megaquagga.local/wp-content/themes/twentytwenty/style.css?ver=1.0, Match: 'Version: 1.0' |

| **Vulnerability** | **Outdated WordPress Core Version** |
|---|---|
| CVE | CVE-2019-9978 - Social Warfare |
| Severity | Medium (CVSS SCORE: 6.1) |
| OWASP Top 10 | A03 (Injection) |
| Risk | Risk is high, as publicly-available exploits exist |
| Steps to exploit | 1. Created a payload text file with input or code to remotely execute a command or program<br>2. Created a simple webserver to host payload<br>3. Deployed exploitable url (found in CVE-2019-9978), adjusting parameters accordingly |
| Evidence | WPScan output:<br><br>social-warfare<br>\| Location: http://www.megaquagga.local/wp-content/plugins/social-warfare/<br>\| Last Updated: 2024-09-17T20:18:00.000Z<br>\| [!] The version is out of date, the latest version is 4.5.4<br>\|<br>\| Found By: Urls In Homepage (Passive Detection)<br>\| Confirmed By:<br>\| Urls In 404 Page (Passive Detection)<br>\| Comment (Passive Detection) |

| | |
|---|---|
| | \|<br>\| Version: 3.5.2 (100% confidence)<br>\| Found By: Comment (Passive Detection)<br>\| - http://www.megaquagga.local/, Match: 'Social Warfare v3.5.2'<br>\| Confirmed By:<br>\| Query Parameter (Passive Detection)<br>\| - http://www.megaquagga.local/wp-content/plugins/social-warfare/assets/css/style.min.css?ver=3.5.2<br>\| - http://www.megaquagga.local/wp-content/plugins/social-warfare/assets/js/script.min.js?ver=3.5.2 |

# EXPLOITATION AND POST-EXPLOITATION

## EXPLOITATION PHASE

- Was able to gain access to list of all user accounts on target system
- Was able to create a reverse shell, and later upgrade to a Meterpreter implant
- Utilized the publicly-available exploit

## POST-EXPLOITATION PHASE

- Was able to gain administrative access to command-line-interface
- Was able to view and alter target system's directories and files
- Was able to acquire user's access credentials
- Was able to alter web scripts on publicly-used web pages

# RECOMMENDATIONS

## Recommendation #1: Update software/plugins flagged for outdated versions

Acquire and install most recent updates and patches for the following softwares/plugins: *twentytwenty, WP Advanced Search, WP File Upload, Social Ware*

## Recommendation #2: Conduct monthly auditing of all plugins

Create and conduct a monthly auditing report to confirm most-updated versions of each plugin are installed. Also check for previously discovered exploits on past vulnerabilities if a new method is found.

## Recommendation #3: Configure SIEM tools for behavioral analytics

Configure the SIEM tools for behavioral analytics. This will account for any traffic that is considered abnormal due to factors such as timing, amount, or destination even if a reverse shell or Meterpreter implant was installed unknowingly.

# CONCLUSION

Maintaining up-to-date versions and patches is a crucial step to any company increasing their security posture. By regularly checking and updating patches and systems, you can ensure you are most defended and against any newly discovered vulnerabilities that are created.